

SMART CONTRACT SECURITY AUDIT – CROWDFUNDING

OnePage Visual Audit Report (OWASP Smart Contract Top 10 2026)

Purpose: Crowdfunding contract that accepts contributions, allows owner withdrawal, and provides refunds after a deadline.

Risk	Severity	SWC	OWASP
Owner can withdraw all funds before goal/deadline	Critical	SWC-105	SC01 Access Control / SC08 Economic Risks
Refund does not reset contribution balance (multiple refunds possible)	Critical	SWC-107	SC03 Logic Errors
Reentrancy in refund()	High	SWC-107	SC05 Reentrancy
Campaign goal is never enforced	Medium	SWC-135	SC03 Logic Errors

Root Cause: refund() performs an external call before updating user state and never clears contributions[msg.sender]. Additionally, withdrawAll() allows unrestricted owner extraction of all ETH regardless of campaign status.

Business Logic Findings: Contributors can repeatedly claim refunds, potentially draining all ETH. The owner can withdraw funds at any time, defeating crowdfunding guarantees. The goal variable is effectively unused.

BENCHMARK METRICS

Time_seconds: 80 | Confidence: 0.98 | Total_findings: 4
Critical: 2 | High: 1 | Medium: 1 | Low: 0
Precision_estimate: 0.97 | Coverage_estimate: 1.00 | Risk_score: 95/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - ELECTIONCHAIN

One-Page Visual Security Report

Purpose: On-chain voting system. Registered users can vote once for a candidate. Key risk: No access control on voter registration functions allows arbitrary manipulation of election participation.

Risk	Severity	SWC	OWASP
Unauthorized voter registration	Critical	SWC-105	SC01 Access Control
Unauthorized voter re-registration	Critical	SWC-105	SC01 Access Control
Infinite voting via reRegister()	Critical	SWC-105	SC08 Economic/Logic
Election result manipulation	High	SWC-105	SC03 Logic Errors
Missing admin role	High	SWC-105	SC01 Access Control
No audit/event trail	Low	N/A	SC10 Monitoring

Root Cause: registerVoter() and reRegister() are public and lack authorization checks. Any address can register or re-register any voter, enabling unlimited vote recycling and election manipulation.

BENCHMARK METRICS

Time_seconds: 35 | Confidence: 0.97 | Total_findings: 6
Critical: 3 | High: 2 | Medium: 0 | Low: 1
Precision_estimate: 0.95 | Coverage_estimate: 0.99 | Risk_score: 95/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - GOVDAOCORE

One-Page Visual Audit Report

Purpose: DAO membership registry with a compute() function that iterates over all members. Users can freely join. Contract can receive ETH but has no withdrawal mechanism.

Risk	Severity	SWC	OWASP
Unbounded loop DoS in compute()	High	SWC-128	SC10 Denial of Service
Gas exhaustion via member spam	High	SWC-128	SC08 Economic Risks
Unlimited membership entries	Medium	SWC-135	SC03 Logic Errors
Duplicate member registrations	Medium	SWC-135	SC03 Logic Errors
Locked ETH (no withdrawal path)	Medium	SWC-132	SC08 Financial Risks
Missing governance controls	Low	N/A	SC01 Access Control

Root Cause: compute() executes $O(n^2)$ nested loops over a user-controlled array. Attackers can continuously call join() to inflate members.length and eventually make compute() impractical due to gas constraints.

Business Logic Findings: No membership uniqueness checks, no governance permissions, and received ETH becomes permanently locked because no withdrawal function exists.

BENCHMARK METRICS

Time_seconds: 40 | Confidence: 0.96 | Total_findings: 6
Critical: 0 | High: 2 | Medium: 3 | Low: 1
Precision_estimate: 0.94 | Coverage_estimate: 0.99 | Risk_score: 72/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT – HIDENTREASURY

OnePage Visual Audit Report

Purpose: ETH custody contract with deposits, withdrawals and owner-controlled treasury transfers.

Risk	Severity	SWC	OWASP
Owner can drain all user funds via transferToTreasury()	Critical	SWC-105	SC01 Access Control
Insolvency: balances mapping not synchronized with treasury withdrawals	High	SWC-105	SC08 Financial Risks
Users may be unable to withdraw despite positive balances	High	SWC-132	SC08 Financial Risks
changeOwner() accepts zero address ownership	Low	N/A	SC01 Access Control

Root Cause: The contract tracks user liabilities in balances while allowing the owner to move ETH out of the contract without reducing those liabilities, creating insolvency risk.

Business Logic Findings: The owner can effectively drain user funds. Withdrawals may fail even when balances show sufficient credit. This creates a custodial rug-pull scenario.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.98 | Total_findings: 4

Critical: 1 | High: 2 | Medium: 0 | Low: 1

Precision_estimate: 0.96 | Coverage_estimate: 1.00 | Risk_score: 91/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - HOTELBOOKING

One-Page Visual Audit Report

Purpose: Hotel reservation contract where users pay ETH to reserve rooms. Hotels are registered by the owner. Contract accepts ETH payments and stores hotel metadata.

Risk	Severity	SWC	OWASP
Locked ETH (no withdrawal mechanism)	High	SWC-132	SC08 Financial Risks
Booking logic broken (reservations never stored)	Medium	SWC-135	SC03 Logic Errors
Unused customerBookings mapping	Low	N/A	SC03 Logic Errors
Gas growth in booking queries	Low	SWC-128	SC10 Denial of Service

Root Cause:

bookHotel() validates payment and creates a Booking structure in memory, but never stores it inside hotels[hotelName].bookings or customerBookings. Users pay successfully while reservation state is never persisted.

Business Logic Findings: No reservation is recorded after payment. Customer history is never updated. ETH enters the protocol but cannot be withdrawn by any actor, resulting in permanently locked funds.

BENCHMARK METRICS

Time_seconds: 55 | Confidence: 0.97 | Total_findings: 4
Critical: 0 | High: 1 | Medium: 1 | Low: 2
Precision_estimate: 0.95 | Coverage_estimate: 1.00 | Risk_score: 61/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT – LOTERY

One-Page Visual Audit Report (OWASP SC Top 10 2026 + SWC Registry)

Purpose: Lottery contract where users enter by paying exactly 0.01 ETH. A winner receives the entire contract balance.

Risk	Severity	SWC	OWASP
Insecure Randomness	Critical	SWC-120	SC09 Insecure Randomness
Unauthorized Winner Selection	High	SWC-105	SC01 Access Control
Front-Running / MEV	High	N/A	SC05 MEV & Front-Running
DoS by Winner Revert	Medium	SWC-113	SC10 Denial of Service
Missing Operational Controls	Low	N/A	SC01 Access Control

Root Cause: Winner selection depends on block.timestamp, msg.sender and players.length. These values are predictable or influenceable. Additionally, pick() can be called by any address.

Business Logic Findings: The lottery outcome is manipulable. Attackers can strategically trigger draws. Validators may influence timestamps. A malicious winner contract may block settlement by reverting.

BENCHMARK METRICS

Time_seconds: 70 | Confidence: 0.95 | Total_findings: 5
Critical: 1 | High: 2 | Medium: 1 | Low: 1
Precision_estimate: 0.93 | Coverage_estimate: 1.00 | Risk_score: 84/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - NFTBAZAAR

One-Page Visual Audit Report

Purpose: Simplified NFT marketplace where sellers list NFTs and buyers purchase them by sending ETH. The contract records ownership in a mapping and forwards payments to the current seller.

Risk	Severity	SWC	OWASP
Unauthorized NFT listing	Critical	SWC-105	SC01 Access Control
Anyone can overwrite seller and price	Critical	SWC-105	SC01 Authorization
No ownership validation before sale	High	SWC-284	SC03 Business Logic
Fake NFT sales / asset spoofing	High	SWC-841	SC08 Economic Risks
Global seller/price state corruption	Medium	SWC-135	SC03 Logic Errors
Front-running of listings	Medium	SWC-114	SC08 MEV Risks

Root Cause: list() lacks ownership verification and updates a single global seller/price pair. Any user can become the active seller and set arbitrary prices regardless of NFT ownership.

Business Logic Findings: NFT ownership is never validated before purchase. Attackers can list arbitrary token IDs, overwrite legitimate listings, and receive buyer funds for assets they do not own.

BENCHMARK METRICS

Time_seconds: 40 | Confidence: 0.98 | Total_findings: 6

Critical: 2 | High: 2 | Medium: 2 | Low: 0

Precision_estimate: 0.96 | Coverage_estimate: 0.99 | Risk_score: 96/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - NFTMINTARENA

One-Page Visual Audit Report

Purpose: NFT minting sale contract with configurable mint price, supply cap and owner withdrawal mechanism. Users pay ETH to mint while the owner controls pricing and treasury withdrawals.

Risk	Severity	SWC	OWASP
Centralized price manipulation	Medium	SWC-105	SC01 Access Control & Governance
No refund for excess ETH	Medium	SWC-135	SC08 Economic Risks
Owner can change price at any time	Medium	SWC-105	SC01 Governance Risks
Missing withdrawal event logging	Low	N/A	SC10 Monitoring & Auditability
No ownership transfer mechanism	Low	SWC-100	SC01 Governance
MEV/user pricing uncertainty	Low	N/A	SC08 Economic Risks

Root Cause: Administrative functions are centralized in the owner account. Users must trust the owner not to modify mintPrice unexpectedly. Overpayments are accepted without refunding the excess amount.

Business Logic Findings: No critical reentrancy or arithmetic flaws were identified. The main risks stem from governance centralization, lack of refund logic for overpayments, and limited operational transparency.

BENCHMARK METRICS

Time_seconds: 35 | Confidence: 0.94 | Total_findings: 6
Critical: 0 | High: 0 | Medium: 3 | Low: 3
Precision_estimate: 0.93 | Coverage_estimate: 0.99 | Risk_score: 38/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - SAFEVAULT

One-Page Visual Audit Report

Purpose: ETH vault that records user deposits and allows a withdrawal-like administrative function. The contract can also receive ETH directly.

Risk	Severity	SWC	OWASP
Unrestricted adminWithdraw()	Critical	SWC-105	SC01 Access Control
Complete contract drain	Critical	SWC-105	SC08 Economic Risks
Missing owner/admin role	High	SWC-105	SC01 Authorization
User deposits not protected	High	SWC-284	SC08 Asset Protection
Accounting/funds inconsistency	Medium	SWC-135	SC03 Logic Errors
No user withdrawal mechanism	Medium	SWC-132	SC08 Financial Risks

Root Cause: adminWithdraw() lacks any authorization check. Any external account can call the function and receive the entire contract balance.

Business Logic Findings: deposits are tracked per user, but the withdrawal path ignores deposit ownership and transfers all ETH to the caller. This breaks custody guarantees and enables total fund theft.

BENCHMARK METRICS

Time_seconds: 30 | Confidence: 0.99 | Total_findings: 6
Critical: 2 | High: 2 | Medium: 2 | Low: 0
Precision_estimate: 0.98 | Coverage_estimate: 1.00 | Risk_score: 99/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - SECUREVOTEMULTISIG

One-Page Visual Audit Report

Purpose: Simplified multisig wallet where approvals are recorded and transactions can be executed after reaching a threshold.

Risk	Severity	SWC	OWASP
Anyone can approve transactions	Critical	SWC-105	SC01 Access Control
Unlimited transaction re-execution	Critical	SWC-114	SC03 Logic Errors
No owner verification in approve()	High	SWC-105	SC01 Access Control
No binding between txHash and tx details	High	SWC-841	SC03 Business Logic
DoS risk from unbounded owner loop	Medium	SWC-128	SC10 Denial of Service
No replay protection	Medium	SWC-121	SC03 Business Logic

Root Cause: approve() lacks owner authorization checks and execute() never marks transactions as executed. Approvals can be forged and the same transaction can be replayed indefinitely.

Business Logic Findings: txHash is not cryptographically linked to (to,value). Previously approved hashes may be reused to authorize arbitrary transfers, enabling fund theft.

BENCHMARK METRICS

Time_seconds: 45 | Confidence: 0.97 | Total_findings: 6
Critical: 2 | High: 2 | Medium: 2 | Low: 0
Precision_estimate: 0.95 | Coverage_estimate: 0.99 | Risk_score: 95/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - SIMPLEAUCTION

One-Page Visual Audit Report

Purpose: Basic auction contract where users submit bids and the seller ends the auction and receives the highest bid.

Risk	Severity	SWC	OWASP
No refund mechanism for outbid users	Critical	SWC-105	SC08 Economic Risks
Permanent ETH lock for losing bids	Critical	SWC-132	SC08 Financial Risks
Auction accounting inconsistency	High	SWC-135	SC03 Logic Errors
Seller receives only highestBid while contract may hold more ETH	High	SWC-128	SC08 Financial Risks
Centralized auction termination	Low	SWC-105	SC01 Access Control
No auction end time	Low	SWC-116	SC03 Business Logic

Root Cause: Each new bid overwrites highestBid and highestBidder without tracking or refunding previous bidders. ETH sent by losing bidders remains trapped in the contract.

Business Logic Findings: Multiple bids accumulate ETH in the contract, but endAuction() transfers only highestBid to the seller. Remaining ETH becomes permanently locked with no recovery path.

BENCHMARK METRICS

Time_seconds: 42 | Confidence: 0.97 | Total_findings: 6
Critical: 2 | High: 2 | Medium: 0 | Low: 2
Precision_estimate: 0.95 | Coverage_estimate: 0.99 | Risk_score: 89/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - TOKENORACLEDEX

One-Page Visual Audit Report

Purpose: Simplified token exchange using an internal price oracle. Users buy synthetic balances with ETH and can sell balances back for ETH.

Risk	Severity	SWC	OWASP
Unrestricted oracle price control	Critical	SWC-105	SC02 Price/Oracle Risks
Market manipulation via setPrice()	Critical	SWC-105	SC08 Economic Risks
Protocol insolvency risk	High	SWC-128	SC08 Financial Risks
Division by zero in sell()	High	SWC-369	SC03 Logic Errors
Unsafe external call in sell()	Medium	SWC-107	SC05 External Interactions
Price can be arbitrarily changed between buy/sell	Medium	SWC-841	SC03 Business Logic

Root Cause: setPrice() has no access control. Any user can set any price value, enabling manipulation of buy() and sell() calculations and extraction of value from the protocol.

Business Logic Findings: The protocol trusts a fully user-controlled oracle. Attackers can distort pricing, create unfair payouts, trigger insolvency conditions, or set price=0 causing sell() failures.

BENCHMARK METRICS

Time_seconds: 42 | Confidence: 0.97 | Total_findings: 6
Critical: 2 | High: 2 | Medium: 2 | Low: 0
Precision_estimate: 0.95 | Coverage_estimate: 0.99 | Risk_score: 94/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - VAULTBANK

One-Page Visual Audit Report

Purpose: Simple ETH vault allowing users to deposit and withdraw balances. Balances are tracked internally and ETH is transferred during withdrawals.

Risk	Severity	SWC	OWASP
Reentrancy in withdraw()	Critical	SWC-107	SC05 Reentrancy
Funds drain via recursive withdrawals	Critical	SWC-107	SC08 Economic Risks
Checks-Effects-Interactions violation	High	SWC-107	SC05 Reentrancy
Global insolvency risk	High	SWC-128	SC08 Financial Risks
No reentrancy protection	Medium	SWC-107	SC05 Reentrancy
Unused owner role	Low	SWC-135	SC03 Logic Errors

Root Cause: withdraw() performs an external call before updating the user's balance. An attacker contract can re-enter withdraw() repeatedly before the balance is reduced.

Business Logic Findings: Successful reentrancy can drain ETH belonging to other users. The contract violates the Checks-Effects-Interactions pattern and lacks ReentrancyGuard.

BENCHMARK METRICS

Time_seconds: 38 | Confidence: 0.99 | Total_findings: 6
Critical: 2 | High: 2 | Medium: 1 | Low: 1
Precision_estimate: 0.97 | Coverage_estimate: 0.99 | Risk_score: 97/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - YIELDSTAKE

One-Page Visual Audit Report

Purpose: ETH staking contract where users deposit, receive rewards and withdraw funds. The contract tracks balances in a mapping and transfers ETH on withdrawal.

Risk	Severity	SWC	OWASP
Arbitrary reward minting	Critical	SWC-105	SC08 Economic Risks
Infinite balance inflation	Critical	SWC-105	SC03 Logic Errors
Protocol insolvency	High	SWC-128	SC08 Financial Risks
Unrestricted reward function	High	SWC-105	SC01 Access Control
Locked withdrawals after inflation	Medium	SWC-128	SC10 DoS
Missing reward authorization model	Medium	SWC-105	SC01 Access Control

Root Cause: reward(uint256 r) allows any caller to increase their own stake balance without depositing ETH. Internal accounting can be inflated arbitrarily while actual ETH reserves remain unchanged.

Business Logic Findings: Attackers can mint unlimited virtual balances, causing insolvency and preventing legitimate withdrawals once the contract balance is exhausted.

BENCHMARK METRICS

Time_seconds: 40 | Confidence: 0.98 | Total_findings: 6
Critical: 2 | High: 2 | Medium: 2 | Low: 0
Precision_estimate: 0.96 | Coverage_estimate: 0.99 | Risk_score: 96/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A